Information Security Framework of Policies

WM279-18
Information Risk and Security Management

5655691

Table of contents

1 Executive Summary……[1]
2 Review of IT and Policy Failures……[1]
2.1 Failure 1: Identity Verification Gaps……[1]
2.2 Failure 2: Privilege Abuse & Data Exfiltration……[1]
2.3 Failure 3: Vendor Due Diligence……..[1]
2.4 Systemic Interdependence……[2]
3 Policy Analysis……[3]
3.1 Policy 1: Mandatory Biometric Identity Re-Verification…….……[3]
3.2 Policy 2: Least Privilege Access Management……[4]
3.3 Policy 3: Cross-Discipline Insider Threat Program……..[5]
3.4 Policy 4: Vendor Due Diligence & Sanctions Screening……..[6]
3.5 Synthesis: Interdependence of Policies……[7]
4 Recommendations……[8]
4.1 Priority 1 (Days 0-30): Policy 1 - Biometric Identity Re-Verification……..[8]
4.2 Priority 2 (1-3 Months): Policy 2 - Least Privilege Access Management…….[8]
4.3 Priority 3 (3-6 Months): Policy 3 - Cross-Discipline Insider Threat Program…..[8]
4.4 Priority 4 (6-12 Months): Policy 4 - Vendor Due Diligence……[8]
4.5 Synthesis……[8]
5 References……[9]
6 Appendix……[10]

1 **Executive Summary**

News reports of the North Korean IT worker scheme [1,2,3] reveal a pattern of identity, access and governance failures. The following analysis assumes Mongrov Inc. also experienced similar failures. Three interrelated failures created systemic inconsistency across identity verification, access control and vendor governance assumed to have occurred in the Mongrov Inc. case, which also contributed to the $88M sanctions evasion and data exfiltration.

2 **Review of IT and Policy Failures**

2.1 ***Failure 1: Identity Verification Gaps (HR & Policy)***

The HR teams failed to distinguish between the person on an application and the person performing the job. North Korean operatives used "false, stolen, and borrowed identities" to secure remote positions, where they remained undercover. Standard background checks were circumvented using stolen Social Security numbers, false resumes containing "experience with tools that didn't exist during stated employment periods", and VoIP phone numbers, untraceable to their physical location [3]. There was no re-verification after hiring these workers, and most critically, there lacked identity re-assessment. Under NIST SP 800-53 control IA-2, firms are required to "uniquely identify organisational users" [4], a requirement that included remote contractors, to which Mongrov Inc. appears to have not met.

2.2 ***Failure 2: Privilege Abuse & Data Exfiltration (IT)***

After being hired, disguised workers gained privileged access due to the companies' failure to enforce the principle of Least Privilege, providing them entry far beyond their functional requirements, some using their access privileges to "steal info such as proprietary source code" [2]. In other cases documented by the DOJ, in early 2024 a co-conspirator "remotely accessed company laptops containing technical data", which included ITAR-controlled military technology [1]. This analysis assumes a similar pattern of unauthorised access and data exfiltration occurred at Mongrov Inc. This would violate NIST AC-6 control of Least Privilege, which requires granting users only necessary access to complete their tasks [5]. Furthermore, control SI-3 [6] mandates "malicious code protection mechanisms at information system entry and exit points".

2.3 ***Failure 3: Vendor Due Diligence (Policy)***

The DOJ indictment identifies eight front companies, including "Eden Programming Solutions, Purpleish Tech, and Culture Box" [1], used to infiltrate victim organisations. This analysis assumes Mongrov Inc. outsourced at least one of these related entities. There seemed to lack policies requiring verification of the vendors' physical appearance, ownership or sanctions compliance. This was a governance failure that enabled the first point of compromise into the company.

2.4 ***Systemic Interdependence***

These failures are interconnected, with weak identity verification (Failure 1) enabling the disguised workers to gain privileges left unconstrained by principle of least privilege (Failure 2), with the entry point provided by inadequate vendor governance (Failure 3). Lacking these creates an exploit chain, a risk profile assumed to apply to Mongrov Inc. based on documented patterns.

3 **Policy Analysis**

From the failures identified in Task the following policies should be incorporated into Mongrov Inc.'s framework. Each policy is built on the NIST SP 800-53 framework and mapped to ISO/IEC 27001:2022 Annex A to demonstrate cross-framework consensus. The extension policy is used to address gaps not covered by the frameworks. This analysis assumes none of these policies existed at Mongrov Inc. throughout the incident.

3.1 ***Policy 1: Mandatory Biometric Identity Re-Verification***

NIST Control: IA-2 | ISO 27001:2022 Mapping: A.8.3, A.8.4, A.8.18, A.8.20

This policy addresses Failure 1. Publicly documented cases confirm operatives used "false, stolen, and borrowed identities" [2].

Policy Outline to implement:

1) Biometric verification, such as facial recognition matching government-issued ID, upon hire, and every three months after
2) Multi-factor authentication for all remote access, using hardware tokens or biometrics
3) Associate all authentication events with auditable user records
4) Immediate access revocation upon detecting identity discrepancy

Strengths:
Identity is assured, directly addressing the core failure. The repeated re-verification detects identity substitution post-hiring. The policy aligns with NIST IA-2 [4] and ISO A.8.4, both requiring unique identification of organisational users.

Weaknesses:
Privacy concerns from storing employees' biometric data. Remote technical issues like poor internet or camera quality can create verification difficulties. Implementation costs vary based on deployment scale, but enterprise licensing typically starts at $50,000 annually for a medium-sized company [7]. Employee pushback due to perceived surveillance is an anticipated challenge.

Opportunities:
New AI-based liveness detection technology is being developed to counter deepfake bypass attempts. ISO A.8.18 provides a framework for linking biometric verification and privileged access management [8].

Threats:
The use of biometric data is regulated in multiple jurisdictions [9,10]. Advanced deepfakes may eventually defeat the liveness detection systems in place, and worker classification disputes may create loopholes.

Ethical and legal justification:
Biometric storage raises legitimate privacy concerns, therefore Mongrov Inc. should implement data minimisation by only storing hash biometric templates with retention limits. This balances security with GDPR Article 5(1)(c), ensuring only necessary personal data is collected and processed [11]. The 2026 Microsoft threat report confirms "AI-generated content and synthetic media" now enhance "forged identity documents" [12], rendering static verification insufficient. Quarterly biometric re-verification will prevent the $88 million consequence documented in similar cases. [1]

3.2 ***Policy 2: Least Privilege Access Management***

NIST Control: AC-6 | ISO 27001:2022 Mapping: A.5.15, A.8.2, A.8.18

This policy addresses Failure 2. Documented cases report workers stole "proprietary source code" [2] and ITAR-controlled data [1].

Policy Outline to implement:

1) Just-in-time (JIT) privileged access, granting elevated rights only for specific tasks, revoking them automatically otherwise
2) Separation of duty, so that it requires two users are required when requesting and approving privileged access
3) Session recording of all privileged remote access
4) Quarterly access reviews with manager sign-off, as required by ISO A.8.2 [13]

Strengths:
The blast radius is controlled by limiting access from a compromised account, directly addressing the data exfiltration failure. This aligns with NIST AC-6 [5] and ISO A.5.15, A.8.2 [14,15], both of which mandate least privilege. ISO A.8.2 enables audit trails by requiring documentation of privileged access reviews.

Weaknesses:
User friction is inevitable as the policy would cause legitimate workers to face access request delays. It requires a well-developed identity governance framework which may not prevent data exfiltration if a worker has legitimate read access to sensitive information. Managing exceptions can become administratively burdensome.

Opportunities:
Modern Privileged Access Management (PAM) tools can automate JIT access, and SIEM integration enables real-time anomaly detection. ISO A.8.18 [8] provides guidance on limiting privileged access to specific use cases.

Threats:
Overly restrictive policies may encourage shadow IT use, and JIT models may be unsupported by legacy systems. Worker circumvention is possible, eg// Nisos notes PiKVM devices that "allow remote users to control computers as if physically present, even before the operating system boots" [3], avoiding OS-level access controls entirely, requiring network-level detection (See Policy 3).

Justification:
ISO A.8.2 requires organisations to "restrict and control the assignment and use of privileged access rights" [15], a requirement assumed to be unmet by Mongrov Inc. The PiKVM threat shows OS-level controls are insufficient and must be used with detection capabilities operating at the network layer.

3.3 ***Policy 3: Cross-Discipline Insider Threat Program***

NIST Control: PM-12 | ISO 27001: 2022 Mapping: A.5.7, A.5.24, A.5.25, A.5.26, A.6.8 (Combination - no single control maps fully)

This policy addresses the detection aspect of Failure 2. In documented cases, exfiltration occurred undetected for months [1].

Policy Outline to implement:
1) A cross-discipline insider threat team (security, HR, legal, IT)
2) Centralised analysis of technical signals through access logs and data transfers
3) Mandatory employee insider threat awareness training
4) Legal team participation ensuring compliance of privacy laws

Strengths:
Different data sources are integrated that would otherwise remain separate, addressing both malicious and unintentional insider threats. This is explicitly required by NIST PM-12 [16]. ISO A.5.7 [17] provides a framework for collection while ISO A.5.24-26 [18] provides a well-developed incident response structure.

Weaknesses:
This is resource-intensive, requiring dedicated staff and tools. Privacy risks may cause distrust if not implemented transparently. Hardware-based bypasses (PiKVM) may evade technical monitoring.

Opportunities:
User and Entity Behaviour Analytics (UEBA) tools can automate detection. The program can start being applied to high-risk roles initially.

Threats:
False positives may overwhelm the team and legal constraints on employee monitoring vary by jurisdiction. HR data access may be restricted by data protection authorities, and noted in Policy 2, hardware-based bypasses (PiKVM) [3], may evade technical monitoring entirely, so network-level detection of KVM-over-IP traffic patterns should be integrated.

Ethical and Legal Justification:
Under NIST PM-12, "compelling evidence shows insider crimes are often preceded by nontechnical behaviours" [16]. HR records containing such indicators were likely not analysed at Mongrov Inc., although accessing HR records requires legal safeguards. Legal team participation ensures monitoring complies with GDPR Article 6(1)(f) [19] and Article 88 [20]. Clear notification to employees is required for transparency obligations under GDPR Articles 13-14 [21].

3.4 ***Policy 4: Vendor Due Diligence & Sanctions Screening***

Framework Basis: Extends industry standards and guidance, including ISO A.5.19 (Supplier Relationship Security Control)[22] and NIST SP 800-161 (Supply Chain Risk Management) [23].

This policy addresses Failure 3. The DOJ indictment identifies eight front companies used by the North Korean operatives [1].

Policy Outline to implement:

1) Pre-contract vendor verification including physical existence, ownership disclosure and sanctions screening
2) Quarterly re-screenings of all vendors against main sanctions lists
3) Contractual clauses requiring vendors to disclose subcontractors and supply chain relationships
4) Right-to-audit provisions for high-risk vendors

Strengths:
Infiltration vector is addressed directly by preventing entry at the contracting stage. Right-to-audit clauses shift compliance burden to vendors. The policy aligns with NIST SP 800-161 supply chain risk management guidance [23].

Weaknesses:
Many vendors will refuse intrusive audits. It is costly and time-consuming for extensive vendor portfolios. Legal enforceability of right-to-audit internationally is complex and does not address a vendor's subcontractors beyond one level.

Opportunities:
Automated sanctions screening tools are widely available with low cost and shared vendor intelligence industry groups intelligence are emerging. ISO A.5.19 compliance audits can include vendor verification as an extension [22].

Threats:
Sophisticated adversaries like the DPRK may use shell companies to pass basic checks. Vendors may hide relationships, and cross-border enforcement of right-to-audit is difficult.

Justification:
ISO A.5.19 requires organisations to "define and implement processes for the management of supplier relationships" [22] but does not mandate quarterly re-screening or physical site visits. Given the specific threat model that state-sponsored adversaries are using front companies, simplified verification like document reviews and self-attestation are insufficient. The DOJ indictment confirms said companies "created fake agency websites" [1]. Standard ISO compliance would not detect this, so the extension of having quarterly re-screening and physical verification are reasonable given the $88 million consequence reported in other cases [2].

3.5 ***Synthesis: Interdependence of Policies***

No policy sufficiently addresses all failures. However, identity is reassured (Policy 1), blast radius is limited (Policy 2), detection enabled (Policy 3), and entry prevented at vendor stage (Policy 4).

4 ***Recommendations***

Policy framework implementation is time-consuming and costly, therefore the following priority order is recommended based on cost, risk reduction speed and impact on the identified failures of identity verification, privilege abuse and vendor due diligence.

4.1 ***Priority 1 (Days 0-30): Policy 1 - Biometric Identity Re-Verification***

This is the most urgent priority because disguised workers may be inside Mongrov Inc. Biometric re-verifying all current remote IT workers would identify identity discrepancies. Off-the-shelf solutions exist, enabling deployment within two-three weeks, with costs varying on deployment scale but estimated around $50,000 [7]. Had this policy existed already, the initial compromise (Failure 1) would have been prevented as operatives would not be able to apply for work under stolen identities.

4.2 ***Priority 2 (1-3 Months): Policy 2 - Least Privilege Access Management***

Just-in-time privileged access prevents existing compromised accounts from exfiltrating large volumes of data. Implementation needs to integrate with existing systems but can be introduced gradually, starting with high-risk roles. Had this policy existed alongside Policy 1, the reported data exfiltration of ITAR-controlled material (Failure 2) would have been prevented as access would have been insufficient even with a compromised account.

4.3 ***Priority 3 (3-6 Months): Policy 3 - Cross-Discipline Insider Threat Program***

Detection capabilities establishment takes time due to the need for cross-discipline coordination and UEBA tool tuning. This policy enables ongoing detection of anomalous behaviour that Policies 1 and 2 might miss, including the PiKVM hardware bypass identified [3]. Had this policy existed, the reported exfiltration that lasted months undetected (Failure 2) would have been detected within days or weeks.

4.4 ***Priority 4 (6-12 Months): Policy 4 - Vendor Due Diligence***

This policy addresses the infiltration vector, but prevents future incidents instead of mitigating active threats. It is resource-intensive, requiring vendor audits and contract renegotiations. However, these costs are justified for long-term resilience against state-sponsored adversaries using front companies. Had this policy existed, the front companies identified by the DOJ [1] could not have established a contractual relationship with Mongrov Inc., preventing infiltration entirely.

4.5 ***Synthesis***

Together, these remediations would have broken the attack chain at every stage, targeting identity assumption, data exfiltration and undetected persistence.

5 **References**

[1] U.S. Department of Justice (2026) Two U.S. nationals sentenced for facilitating fraudulent remote information technology worker scheme. Available at: https://www.justice.gov/opa/pr/two-us-nationals-sentenced-facilitating-fraudulent-remote-information-technology-worker

[2] The Register (2024) DOJ indicts alleged DPRK fake tech worker scheme. Available at: https://www.theregister.com/2024/12/13/doj_dpkr_fake_tech_worker_indictment

[3] Nisos (2026) DPRK IT worker fraud and laptop farms. Available at: http://nisos.com/blog/dprk-it-worker-fraud-laptop-farm/

[4] Codific (n.d.) NIST 800-53 v5: Identification and authentication (organizational users). Available at: https://sammy.codific.com/browse/nist-800-53-v5/identification-and-authentication/identification-and-authentication-organizational-users

[5] National Institute of Standards and Technology (NIST) (n.d.) AC-6: Least privilege. Available at: https://csrc.nist.gov/Control-Catalog/AC-6

[6] ARC-IT (n.d.) Security control 223. Available at: https://www.arc-it.us/html/security/control223.htm

[7] SaaSworthy (n.d.) Ping Identity pricing. Available at: https://www.saasworthy.com/product/ping-identity/pricing

[8] ISMS.online (n.d.) ISO 27001 Annex A 8.18: Use of privileged utility programs (2022). Available at: https://www.isms.online/iso-27001/annex-a-2022/8-18-use-of-privileged-utility-programs-2022/

[9] GDPR Info (n.d.) Article 9: Processing of special categories of personal data. Available at: https://gdpr-info.eu/art-9-gdpr/

[10] ACLU of Illinois (n.d.) Biometric Information Privacy Act (BIPA). Available at: https://www.aclu-il.org/campaigns-initiatives/biometric-information-privacy-act-bipa/

[11] GDPR Info (n.d.) Article 5: Principles relating to processing of personal data. Available at: https://gdpr-info.eu/art-5-gdpr/

[12] Microsoft (2026) AI as tradecraft: How threat actors operationalize AI. Available at: https://www.microsoft.com/en-us/security/blog/2026/03/06/ai-as-tradecraft-how-threat-actors-operationalize-ai/

[13] Hightable (n.d.) ISO 27001 Annex A 8.2: Privileged access rights. Available at: https://hightable.io/iso-27001-annex-a-8-2-privileged-access-rights/

[14] ISMS.online (n.d.) ISO 27001 Annex A 5.15: Access control (2022). Available at: https://www.isms.online/iso-27001/annex-a-2022/5-15-access-control-2022/

[15] ISMS.online (n.d.) ISO 27001 Annex A 8.2: Use of privileged access rights (2022). Available at: https://www.isms.online/iso-27001/annex-a-2022/8-2-use-of-privileged-access-rights-2022/

[16] NIST (n.d.) SP 800-53 Rev. 5: PM-12. Available at: https://csf.tools/reference/nist-sp-800-53/r5/pm/pm-12/

[17] ISMS.online (n.d.) ISO 27001 Annex A 5.7: Threat intelligence (2022). Available at: https://www.isms.online/iso-27001/annex-a-2022/5-7-threat-intelligence-2022/

[18] BM Consulting (n.d.) NIS2 vs ISO 27001 comparison. Available at: https://bm.consulting/en/comparisons/nis2-vs-iso27001/

[19] GDPR Info (n.d.) Article 6: Lawfulness of processing. Available at: https://gdpr-info.eu/art-6-gdpr/

[20] GDPR Info (n.d.) Article 88: Processing in the context of employment. Available at: https://gdpr-info.eu/art-88-gdpr/

[21] Information Commissioner's Office (ICO) (n.d.) Right to be informed. Available at: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/right-to-be-informed/

[22] ISMS.online (n.d.) ISO 27001 Annex A 5.19: Information security in supplier relationships (2022). Available at: https://www.isms.online/iso-27001/annex-a-2022/5-19-information-security-supplier-relationships-2022/

[23] National Institute of Standards and Technology (NIST) (2022) SP 800-161 Rev. 1: Cybersecurity supply chain risk management practices. Available at: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-161r1-upd1.pdf

6 **Appendix**

AI declaration: I have used AI to proofread my work for grammatical errors, suggestions for structure and refining my sentences. Each response was critically evaluated and modified before implementation. A majority of prompts included rewording in order to flow better.